

UNIVERSIDAD POLITÉCNICA DEL VALLE DE TOLUCA

NOMBRE DEL PROGRAMA EDUCATIVO:

INGENIERÍA EN TECNOLOGÍAS DE LA INFORMACIÓN

NOMBRE DEL ASIGNATURA:

Seguridad Informática

NOMBRE DE LA PRÁCTICA:

Investigación y demostración controlada de CamPhish y Zphisher

NOMBRE DE LA UNIDAD DE APRENDIZAJE:

Unidad: IV. Tendencias en la seguridad informática

Cuatrimestre:

9°

Grupo:

ITI9VA

FACILITADOR:

Ing. Fernández Martínez Hector Abraham

Alumno:

No.	Nombre	Matricula
1	Loa Camargo Miguel Alejandro	1323443075
2	Camacho Vázquez Roberto Carlos	1323443080
3	Olivarez perez Juan Pablo	1323443119

Junio, 2026

Introducción	3
Objetivos	4
Descripción de Zphisher	4
Descripción de CamPhish	5
Requisitos del Entorno de Práctica (Teórico)	5
Manual técnico con capturas de pantalla y explicación de cada paso realizado.	6
Descripción de los comandos utilizados y su función.	6
Comparativa entre ambas Herramientas	6
Ventajas y Desventajas (Desde la perspectiva del Analista)	7
Riesgos y Consideraciones Éticas	7
Conclusiones	8
Referencias Bibliográficas	9

Introducción

El factor humano sigue siendo considerado uno de los eslabones más vulnerables dentro de la cadena de la seguridad de la información. La ingeniería social, definida como el conjunto de técnicas psicológicas y manipulativas utilizadas para conseguir que los usuarios revelen información confidencial o realicen acciones específicas, ha evolucionado gracias a la automatización de procesos.

Herramientas de software diseñadas originalmente para la concienciación y el *red teaming* (simulación de adversarios) permiten replicar escenarios complejos de ataque en cuestión de segundos. El propósito de esta investigación es analizar conceptualmente el funcionamiento, características y riesgos de dos metodologías automatizadas orientadas al robo de credenciales y a la exfiltración multimedia a través de la web, con el fin de proponer contramedidas efectivas en entornos organizacionales.

Objetivos

Objetivo General

- Analizar desde una perspectiva teórica y educativa los mecanismos de funcionamiento de las herramientas de simulación de ingeniería social Zphisher y CamPhish, identificando sus riesgos y las medidas de prevención necesarias para mitigar ataques de phishing.

Objetivos Específicos

- Definir conceptualmente el propósito, alcance y sistemas operativos compatibles con Zphisher y CamPhish.
- Establecer una comparativa técnica detallada que identifique las ventajas, desventajas y diferencias operativas entre ambos enfoques de ataque.
- Evaluar las implicaciones éticas, legales y de seguridad derivadas del uso indebido de estas tecnologías en la sociedad actual.

Descripción de Zphisher

Zphisher es una herramienta automatizada de código abierto orientada a la simulación de *Credential Phishing* (pesca de credenciales).

- **Finalidad:** Su objetivo principal es demostrar la facilidad con la que un actor malicioso puede suplantar la identidad visual de una plataforma legítima para engañar a un usuario y obtener sus llaves de acceso (usuarios y contraseñas).
- **Mecanismo de funcionamiento:** La herramienta aloja de forma local un servidor web que contiene réplicas exactas (clones de interfaz) de páginas de inicio de sesión de servicios populares (redes sociales, banca en línea, correos electrónicos). Cuando una víctima interactúa con el formulario y presiona el botón de envío, los datos se transmiten mediante el método POST

de HTTP directamente hacia un archivo de registro controlado por el evaluador.

- **Sistemas Operativos:** Está diseñada principalmente para entornos basados en **Linux** (como Kali Linux, Parrot OS, Ubuntu) y entornos emulados en Android (a través de terminales como Termux).

Descripción de CamPhish

CamPhish es una herramienta de simulación que cambia el enfoque del robo de contraseñas hacia la exfiltración de acceso a hardware periférico.

- **Finalidad:** Ilustrar visualmente los riesgos de otorgar permisos de forma indiscriminada a los sitios web que visitamos en el día a día.
- **Mecanismo de funcionamiento:** En lugar de clonar una red social, el sistema genera una página web atractiva o de apariencia inofensiva (por ejemplo, un visor de videos, un festival de música o un juego en línea). El código fuente de esta página invoca directamente a las APIs nativas del navegador del usuario. Si el usuario acepta la solicitud del navegador para compartir su hardware, un script en segundo plano captura transmisiones multimedia y las envía de vuelta al servidor del analista.
- **Sistemas Operativos:** Al igual que la anterior, su entorno natural de ejecución son sistemas operativos **Linux** y emuladores de terminal en **Android**.

Requisitos del Entorno de Práctica (Teórico)

Para realizar análisis controlados de estas herramientas sin poner en riesgo la infraestructura real, se deben cumplir los siguientes requisitos de laboratorio:

- **Aislamiento de Red:** Las máquinas virtuales utilizadas deben configurarse en modo *Host-Only* (Solo anfitrión) o *Red Interna* para evitar que los servidores web locales se expongan accidentalmente a internet.

- **Hipervisor:** Uso de software de virtualización como Oracle VirtualBox o VMware Workstation.
- **Sistema Operativo del Analista:** Distribuciones especializadas en auditoría de seguridad como Kali Linux actualizadas.
- **Intérpretes de Lenguaje:** Contar con entornos de ejecución para scripts (como PHP para levantar los servidores locales, y herramientas de transferencia como curl u openssh).

Manual técnico con capturas de pantalla y explicación de cada paso realizado.

Instalación del Zphisher

```
> sudo pacman -S git php curl wget unzip
[sudo] password for jp.root:
warning: git-2.55.0-1 is up to date -- reinstalling
warning: curl-8.21.0-1 is up to date -- reinstalling
warning: wget-1.25.0-6 is up to date -- reinstalling
warning: unzip-6.0-23 is up to date -- reinstalling
resolving dependencies...
looking for conflicting packages...

Packages (6) argon2-20190702-6  curl-8.21.0-1  git-2.55.0-1  php-8.5.8-1  unzip-6.0-23  wget-1.25.0-6

Total Download Size:    5.69 MiB
Total Installed Size:  78.80 MiB
Net Upgrade Size:       39.26 MiB

:: Proceed with installation? [Y/n] y
:: Retrieving packages...
argon2-20190702-6-x86_64           33.3 KiB   311 KiB/s 00:00 [#####] 100%
php-8.5.8-1-x86_64                 5.7 MiB   15.2 MiB/s 00:00 [#####] 100%
Total (2/2)                        5.7 MiB   14.3 MiB/s 00:00 [#####] 100%
(6/6) checking keys in keyring [#####] 100%
(6/6) checking package integrity [#####] 100%
(6/6) loading package files [#####] 100%
(6/6) checking for file conflicts [#####] 100%
(6/6) checking available disk space [#####] 100%
:: Processing package changes...
(1/6) reinstalling curl [#####] 100%
(2/6) reinstalling git [#####] 100%
(3/6) installing argon2 [#####] 100%
```

```

|-----| | | | | | | | | | |
|_| / | | (~) | |
| / / - _ | | | | | | | | | |
| / / | | \ | | \ | | \ | | \ | |
| / / _ | | ) | | | | \ | | | | _ / |
|-----| | _ / | | | |----| | | \ ----| |
      | |
      | |
      |_|
                                     Version : 2.3.5

[-] Tool Created by htr-tech (tahmid.rayat)

[::] Select An Attack For Your Victim [::]

[01] Facebook           [11] Twitch                [21] DeviantArt
[02] Instagram          [12] Pinterest             [22] Badoo
[03] Google              [13] Snapchat              [23] Origin
[04] Microsoft           [14] Linkedin            [24] DropBox
[05] Netflix             [15] Ebay                 [25] Yahoo
[06] Paypal              [16] Quora                [26] Wordpress
[07] Steam               [17] Protonmail           [27] Yandex
[08] Twitter             [18] Spotify              [28] StackoverFlow
[09] Playstation         [19] Reddit                [29] Vk
[10] Tiktok              [20] Adobe                  [30] XB0X
[31] Mediafire           [32] Gitlab                [33] Github
[34] Discord             [35] Roblox

[99] About              [00] Exit

[-] Select an option : |
```

2PHISHER 2.3.5

```
[01] Localhost
[02] Cloudflared [Auto Detects]
[03] LocalXpose [NEW! Max 15Min]

[-] Select a port forwarding service : 01

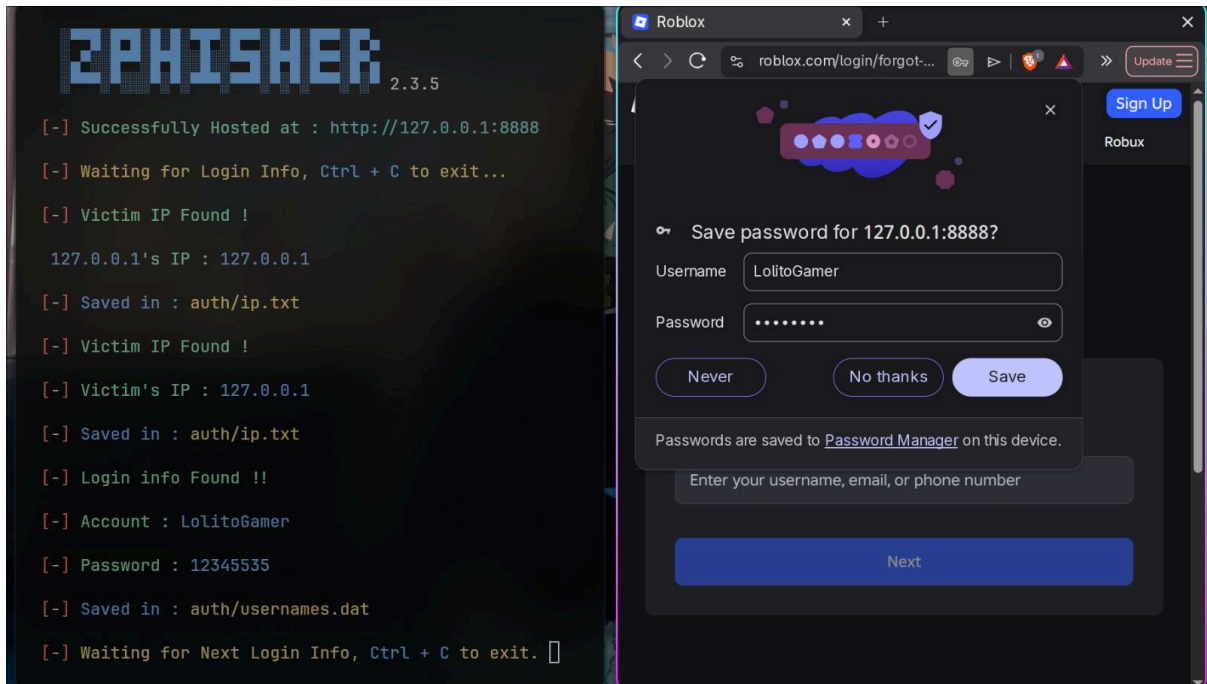
[?] Do You Want A Custom Port [y/N]: y

[-] Enter Your Custom 4-digit Port [1024-9999] : |
```

2PHISHER 2.3.5

```
[-] Successfully Hosted at : http://127.0.0.1:8888

[-] Waiting for Login Info, Ctrl + C to exit...|
```

Descripción de los comandos utilizados y su función.

Comandos utilizados en el Zphisher

Instalación de dependencias

-sudo pacman -S git php curl wget unzip

- **Función:** Utiliza el gestor de paquetes pacman (típico de Arch Linux) con permisos de administrador (sudo) para descargar e instalar las herramientas necesarias que requiere la herramienta de phishing para funcionar: git (control de versiones), php (servidor web local), curl y wget (transferencia de datos/archivos) y unzip (descompresión).

Clonación del repositorio

-git clone https://github.com/htr-tech/zphisher.git

- **Función:** Descarga una copia exacta del código fuente y los archivos de la herramienta automatizada de phishing llamada **Zphisher** directamente desde su repositorio en GitHub a la computadora.

Intento fallido de ingresar a la carpeta

-cd zphisher

- **Función:** Intenta cambiar el directorio actual de la terminal hacia la carpeta del proyecto, pero da un error (No such file or directory) debido a un error de dedo al escribir el nombre (se escribió "zphisher" con una 'n' de más).

Ingreso correcto a la carpeta

-cd zphisher

Función: Cambia con éxito el directorio de trabajo de la terminal a la carpeta recién clonada (zphisher), permitiendo acceder a sus scripts para poder ejecutar la herramienta.

Comparativa entre ambas Herramientas

Criterio Técnico	Zphisher	CamPhish
Tipo de Vector	Phishing tradicional de formularios HTML.	Phishing basado en API / Permisos de navegador.
Dato Exfiltrado	Credenciales de texto (Usuarios, contraseñas, PINs).	Archivos multimedia / Capturas de cámara.

Interacción del Usuario	Alta (Debe teclear su información proactivamente).	Media (Debe hacer clic en "Permitir" en una ventana emergente).
Vulnerabilidad Explotada	Falta de atención al dominio (URL) por parte del usuario.	Exceso de confianza al conceder permisos de hardware.

Ventajas y Desventajas (Desde la perspectiva del Analista)

Zphisher

- **Ventajas:** Cuenta con un catálogo sumamente amplio de plantillas preconfiguradas y automatiza el proceso de clonación sin necesidad de programar el HTML desde cero.
- **Desventajas:** Es altamente dependiente de que el usuario no use gestores de contraseñas (los cuales detectan automáticamente que la URL es falsa y no autorrellenan los datos).

CamPhish

- **Ventajas:** Demuestra de manera muy gráfica el impacto de un ataque en tiempo real, lo que resulta muy útil en campañas corporativas de concienciación.
- **Desventajas:** Si el usuario tiene la cámara bloqueada físicamente o deniega el permiso explícito en el navegador, el ataque falla por completo de forma inmediata.

Riesgos y Consideraciones Éticas

El uso inadecuado de este tipo de herramientas presenta severas implicaciones que todo profesional de la tecnología debe evaluar:

- **Riesgos Legales:** La legislación internacional y local castiga severamente el acceso ilícito a sistemas informáticos. En muchos países, el simple hecho de montar un sitio falso para capturar datos de terceros sin un contrato firmado previo constituye un delito penal relacionado con el fraude y el robo de identidad.
- **Fuga de Datos e Infraestructura:** Muchas de estas herramientas automatizadas ofrecen integrar servidores de tunelización gratuitos de terceros para sacar el tráfico a internet. Utilizar estos servicios implica que los datos de las víctimas pasan por servidores ajenos, lo que puede provocar que actores maliciosos intercepten la información de tus pruebas.
- **Responsabilidad Ética:** La ciberseguridad debe regirse bajo el principio del consentimiento informado. Utilizar estas herramientas contra amigos, familiares o compañeros de clase "como una broma" viola los códigos de ética profesional y destruye la confianza digital.

Conclusiones

La automatización ha democratizado el acceso a herramientas de ataque sofisticadas, permitiendo que incluso usuarios con pocos conocimientos técnicos puedan desplegar campañas de ingeniería social. Sin embargo, el análisis de Zphisher y CamPhish demuestra que los vectores de ataque no explotan fallos en el código de los sistemas, sino descuidos en el comportamiento humano y la falta de verificación de los entornos digitales. La mejor defensa contra estas amenazas es una combinación de controles tecnológicos estrictos (como la autenticación de doble factor y políticas de privilegios mínimos en navegadores) junto con una educación continua y crítica de los usuarios.

Referencias Bibliográficas

- Mitnick, K. D., & Simon, W. L. (2002). *The Art of Deception: Controlling the Human Element of Security*. John Wiley & Sons.
- Organismo Internacional de Normalización. (2022). *Seguridad de la información, ciberseguridad y protección de la privacidad — Controles de seguridad de la información* (Norma ISO/IEC 27002:2022). <https://www.iso.org/standard/75624.html>
- Stallings, W. (2018). *Effective Cybersecurity: A Guide to Using Best Practices and Standards*. Addison-Wesley Professional.



TENDENCIAS EN LA SEGURIDAD INFORMÁTICA: AUTOMATIZACIÓN DE LA INGENIERÍA SOCIAL.

Integrantes:

Camacho Vázquez Roberto Carlos

Loa Camargo Miguel Alejandro

Olivares Pérez Juan Pablo



¿QUÉ SON CAMPHISH Y ZPHISHER?



- *CamPhish: Es un script diseñado específicamente para realizar ataques de ingeniería social orientados a la captura de imágenes biométricas (fotografías) a través de la cámara web del dispositivo objetivo, engañando al usuario para que otorgue permisos en su navegador*
- *Zphisher: Es un framework integral y automatizado de phishing. Su función es generar clones exactos de páginas de inicio de sesión de más de 30 plataformas reconocidas para interceptar e investigar credenciales de acceso y direcciones IP.*

CARACTERÍSTICAS PRINCIPALES

CamPhish:

- *Enfoque en la extracción de medios visuales, no contraseñas.*
- *Uso de plantillas de "cebo" (ej. generadores de likes, sitios de streaming).*
- *Requiere interacción activa de la víctima con los controles de seguridad del navegador.*

Zphisher:

- *Catálogo masivo de plantillas (redes sociales, correos, juegos).*
- *Captura de datos en texto plano.*
- *Integración nativa con múltiples servicios de túneles dinámicos (Port Forwarding) para exponer el servidor local a internet sin configuraciones complejas de red.*



PREPARACIÓN DEL ENTORNO



Al estar basadas en Bash, estas herramientas no se "instalan" como un binario tradicional, sino que se clonan y se ejecutan desde su código fuente.

Requisitos del sistema:

- *Un sistema operativo tipo Unix (Arch Linux, distribuciones basadas en Debian, etc.).*
- *Gestor de paquetes: En Arch se utilizaría pacman para asegurar que el sistema tenga las dependencias base.*
- *Dependencias lógicas: Intérprete web local (PHP), herramientas de transferencia de datos (cURL, Wget), y utilidades de compresión (Unzip).*

DESCRIPCIÓN FUNCIONAL DE LOS COMANDOS



Comandos de Control de Versiones: Se utilizan para interactuar con repositorios remotos y descargar el árbol de directorios exacto de la herramienta al equipo local.

- *Comandos de Navegación y Permisos: Fundamental en Linux; se debe navegar al directorio de trabajo y modificar los atributos del archivo principal para otorgarle permisos de ejecución, ya que por defecto el sistema lo bloquea.*

- *Comandos de Ejecución y Dependencias: Al lanzar el script, este interactúa con el shell para verificar si existen los paquetes necesarios (como PHP). Si no, el propio script intenta invocarlos a través del gestor de paquetes del sistema. Finalmente, levanta un puerto local y lo enlaza al túnel seleccionado.*

PREPARACIÓN DEL ENTORNO

Criterio	CamPhish	Zphisher
Vector de ataque	Permisos del navegador (Hardware).	Formularios web falsificados (Software/Credenciales).
Objetivo del dato	Fotografías del usuario.	Usuarios, contraseñas, IPs, <i>User-Agents</i> .
Complejidad del engaño	Alta (El navegador suele alertar del uso de cámara).	Media/Alta (Depende de la inspección de la URL por el usuario).
Infraestructura	Servidor PHP + Túnel.	Servidor PHP + Túneles dinámicos integrados.



RIESGOS, ASPECTOS LEGALES Y USO ÉTICO



Riesgos de Seguridad:

Facilita el robo de identidad, el acceso no autorizado a redes corporativas y el compromiso de datos confidenciales.

1



Marco Legal:

Desplegar estas campañas contra individuos o infraestructuras sin consentimiento explícito es un delito tipificado (fraude informático, suplantación de identidad).

2



Uso Ético:

El único escenario válido para el uso de estos frameworks es bajo un contrato de auditoría de seguridad o en laboratorios académicos estrictamente aislados para fines de investigación, como se realiza en esta materia.

3

CONCLUSIONES Y PREVENCIÓN

LA TECNOLOGÍA DE ATAQUE ES CADA VEZ MÁS ACCESIBLE. LOS FILTROS DE SPAM Y LOS FIREWALLS TRADICIONALES NO SIEMPRE PUEDEN DETECTAR ENLACES GENERADOS DINÁMICAMENTE POR TÚNELES TEMPORALES.

AUTENTICACIÓN MULTIFACTOR (MFA)

Es la medida técnica más efectiva. Invalida las credenciales robadas por Zphisher.



Capacitar a los usuarios en la identificación de URLs anómalas, certificados SSL inválidos y tácticas de urgencia psicológica.

EDUCACIÓN CONTINUA

Bloquear permisos de hardware (cámaras/micrófonos) por defecto a nivel organizacional.

POLÍTICAS DE PRIVACIDAD (ZERO TRUST)

CONCLUSIONES

Aunque herramientas como CamPhish y Zphisher automatizan y facilitan los ataques, la tecnología de seguridad por sí sola no basta. La defensa más efectiva siempre será una combinación de controles técnicos, como el uso obligatorio de MFA, y la educación constante del usuario final para que deje de ser el eslabón más débil

El análisis técnico de cómo operan CamPhish y Zphisher nos obliga a repensar la forma en que construimos y desplegamos software. Al estructurar interfaces dinámicas o gestionar la lógica y las migraciones en bases de datos relacionales, la prioridad ya no puede ser únicamente que la aplicación funcione, sino que sea resistente a la suplantación

Ejecutar estas demostraciones en un entorno de pruebas evidencia la asombrosa velocidad con la que hoy en día se pueden desplegar campañas complejas de ingeniería social. Esto nos demuestra que, al integrarnos al sector productivo, nuestro valor profesional no solo radicará en administrar servidores o programar sistemas eficientes, sino en tener la capacidad de auditar proactivamente la infraestructura

